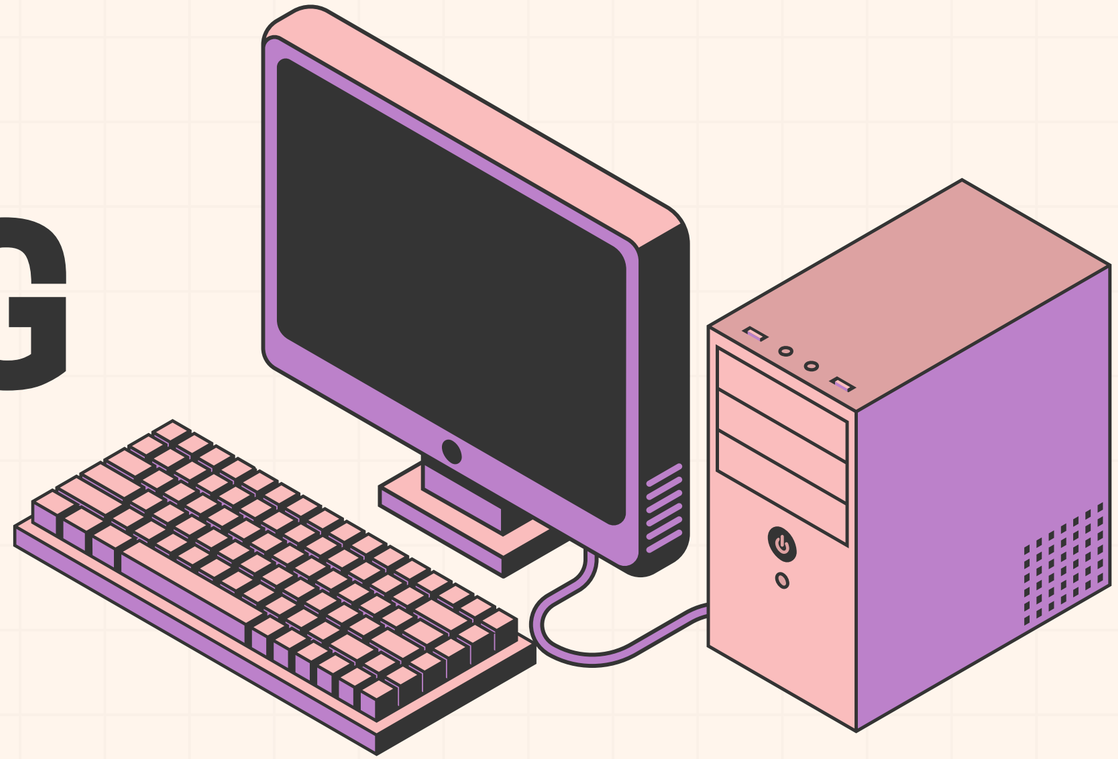
PENTESTING

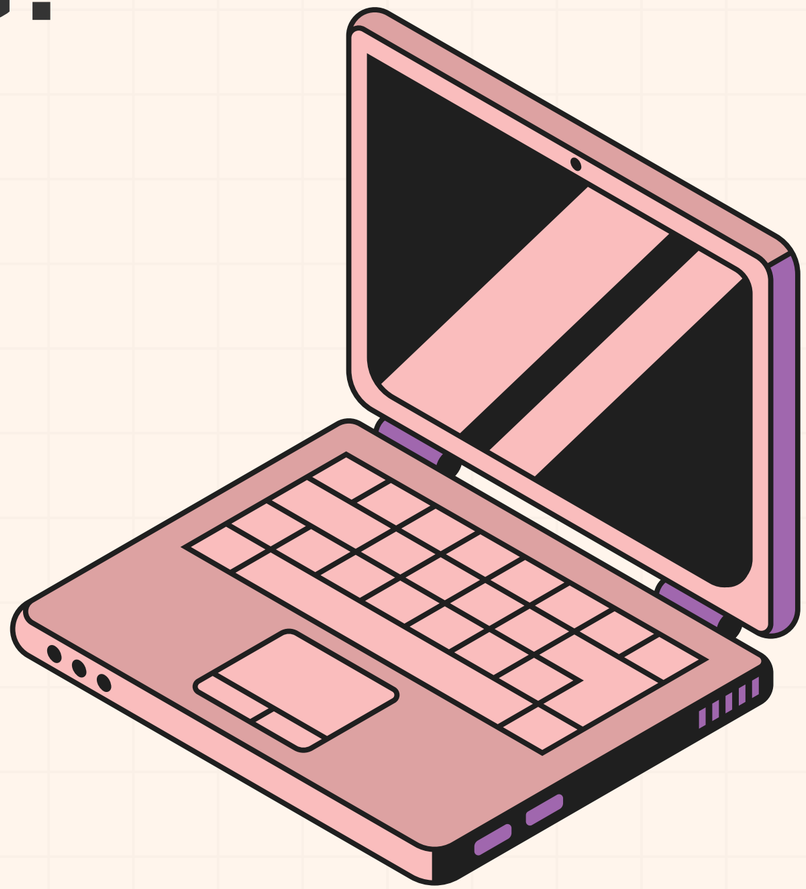
Criptografía y Seguridad



¿QUÉ ES EL PENTESTING?

Pruebas de penetración

Simula ataques controlados y autorizados a sistemas informáticos, redes o aplicaciones con el objetivo de identificar y explotar vulnerabilidades de seguridad antes de que sean aprovechadas por atacantes maliciosos.



¿QUIEN HACE EL PENTESTING?

Lo lleva a cabo un profesional conocido como pentester o hacker ético, también conocidos como hackers de sombrero blanco, utilizan herramientas especializadas para identificar vulnerabilidades técnicas y humanas.

En su mayoría, los servicios de pentesting se suelen subcontratar a proveedores especializados en éste ámbito



OBJETIVO

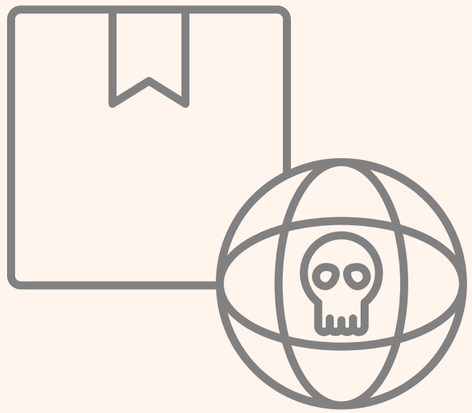
Evalúa el nivel de seguridad, detecta debilidades y prueba la efectividad de las defensas existentes. Este proceso puede ser manual o automatizado y permite comprobar el impacto potencial de las vulnerabilidades detectadas, así como evaluar el cumplimiento de políticas de seguridad y normativas. Los resultados se utilizan para mejorar la seguridad y mitigar riesgos antes de que un atacante real pueda explotarlos



TIPO DE PRUEBAS

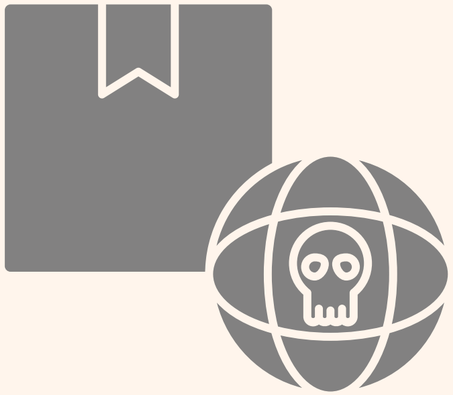
- White Box

Tiene acceso completo al código fuente, documentación de la arquitectura, etc.
Analiza una cantidad enorme de datos disponibles para identificar los posibles puntos débiles. Se realiza análisis de código estático.



- Black Box

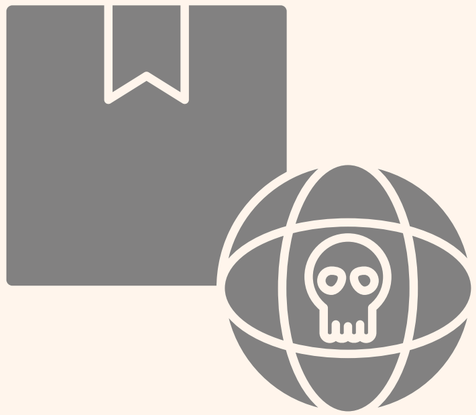
Sin conocimiento interno del sistema, simulando el punto de vista de un atacante externo. Se basa en el análisis dinámico de los programas y sistemas que se están ejecutando.



TIPO DE PRUEBAS

- Gray Box

Tiene acceso y conocimientos de un usuario, potencialmente con elevados privilegios en un sistema. Tiene un conocimiento parcial de los elementos internos, configuración, documentación y arquitectura para equilibrar la simulación.



- Covert

También conocida como double-blind test, es cuando la empresa no es consciente de que una prueba de pentest se está llevando a cabo.

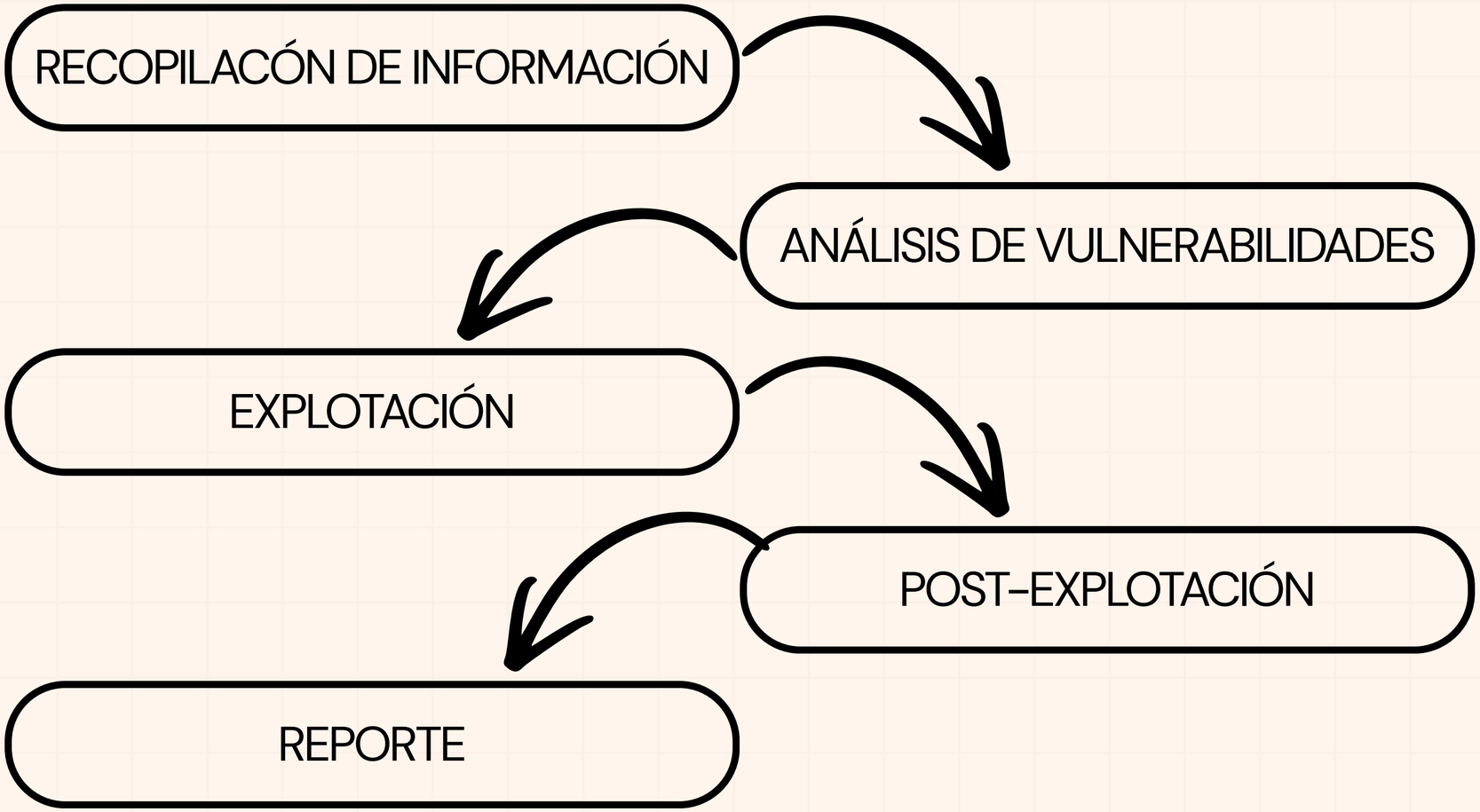
- External

Se realiza la prueba desde fuera de las instalaciones de la compañía, enfrentando la tecnología externa, como sitios web y servidores de red externos. Se puede llevar a cabo desde una ubicación remota.

- Internal

Se realiza la prueba desde la red interna de la empresa. Este tipo de prueba puede determinar cuánto daño puede causar un empleado descontento detrás de un firewall de la empresa

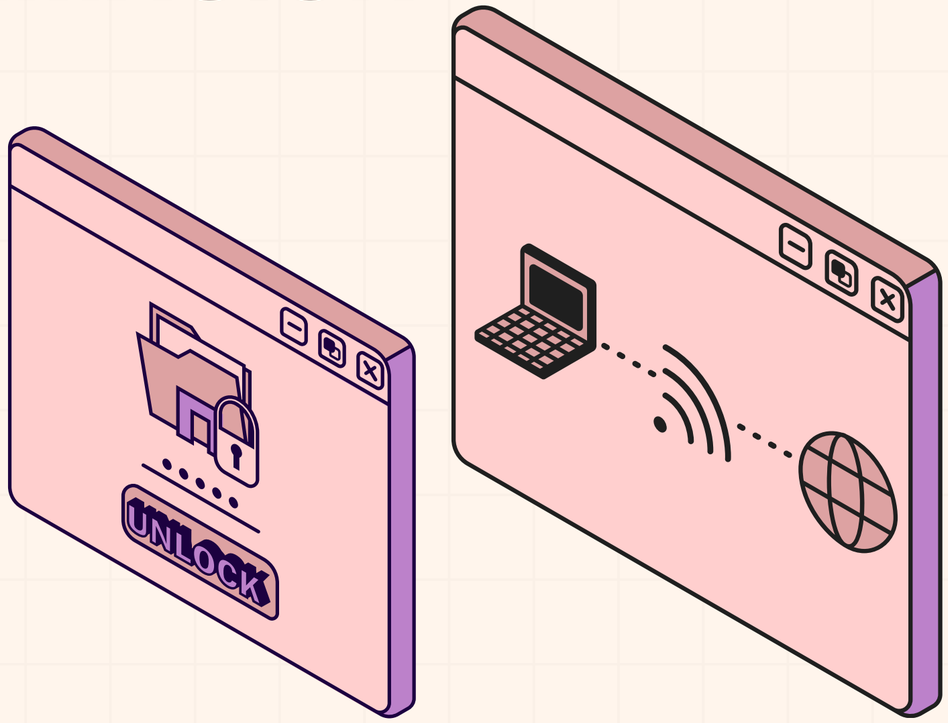
FASES DEL PENTESTING



RECOPILACIÓN DE INFORMACIÓN

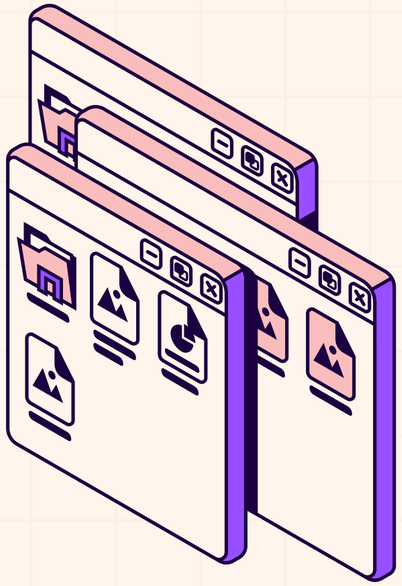
Fase principal del pentest. en esta fase se recolecta toda la información de nuestro objetivo haciendo uso de técnicas como:

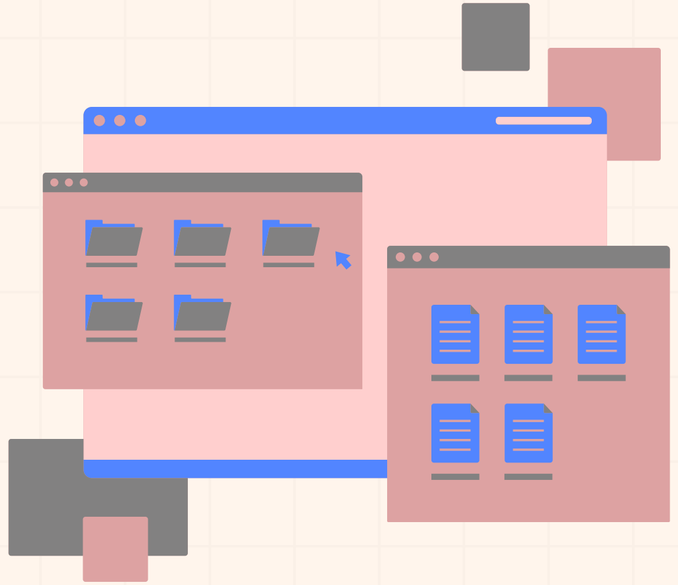
- Escaneo de dominios, IP, puertos, versiones, servicios
- Dorking, motor de búsqueda de Google que puede utilizarse para descubrir datos confidenciales expuestos involuntariamente al público en línea.
- Uso de herramientas automatizadas para obtener información



HERRAMIENTAS UTILES

- Nmap
- Dnsmap
- Dnsrecon
- Subfinder
- Google Dorks
- Redes sociales

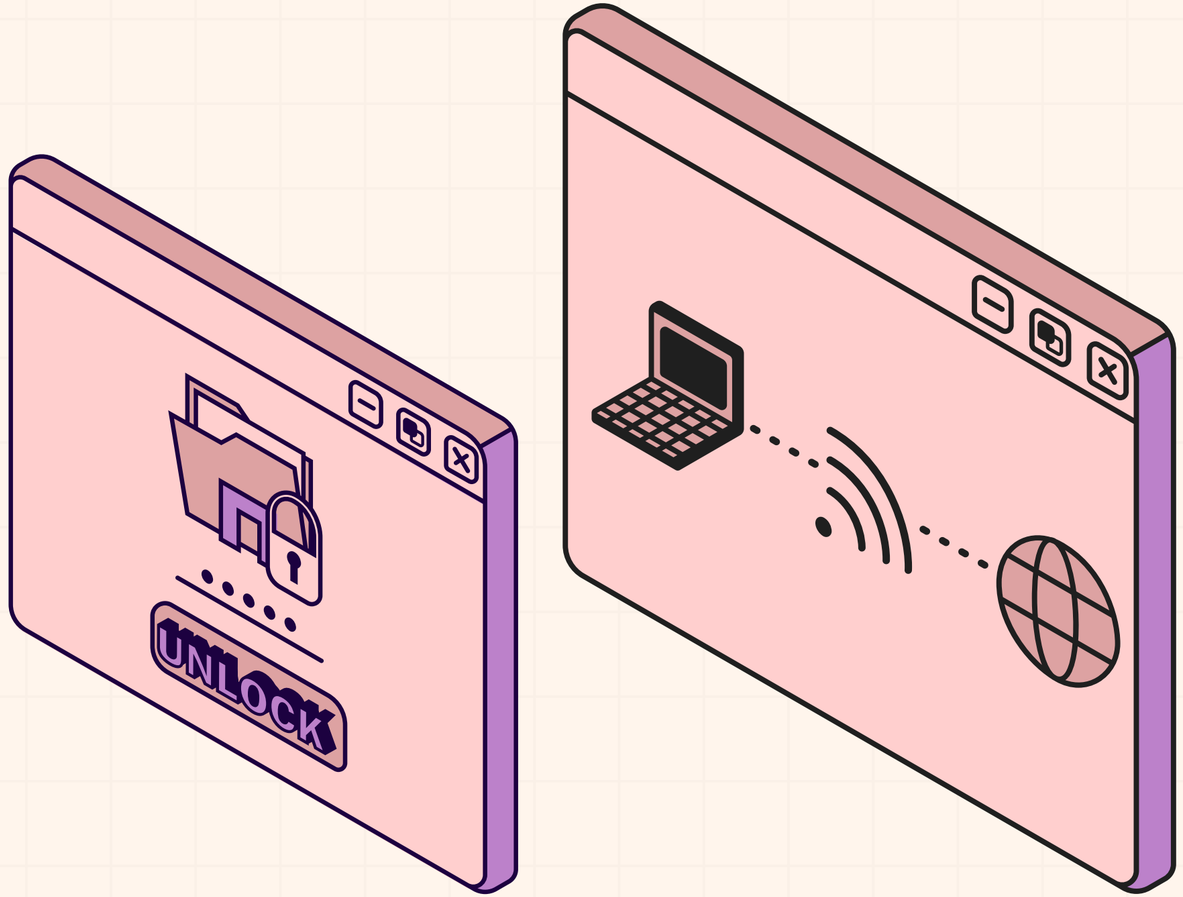




EXPLOTACIÓN DE VULNERABILIDADES

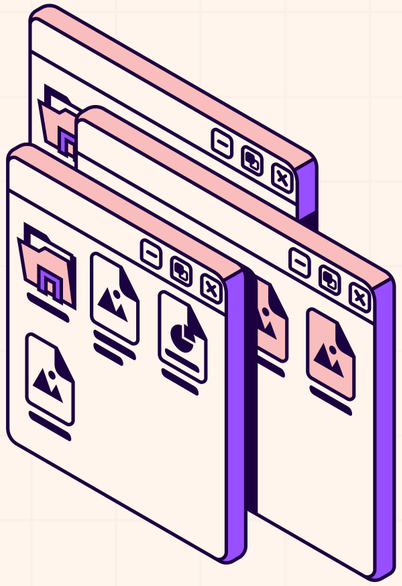
Se aprovechan las vulnerabilidades encontradas en la fase anterior.

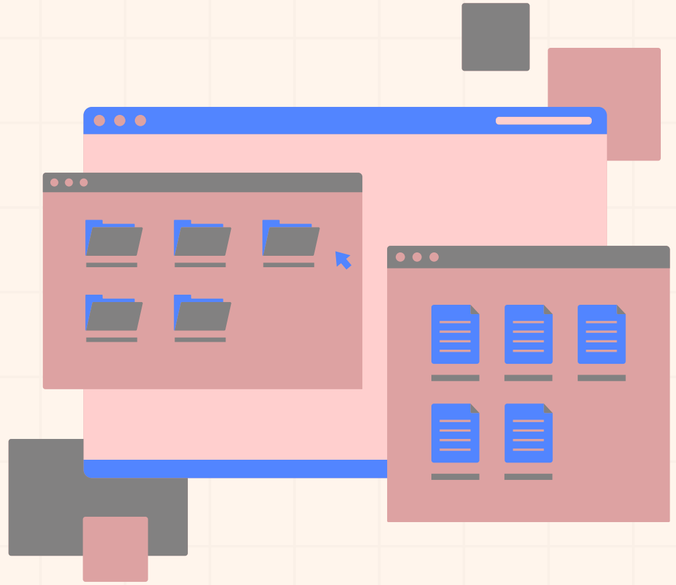
- Escaneo de dominios, IP, puertos, versiones, servicio
- Se ejecutan exploits contra las vulnerabilidades
- Se hace uso de credenciales obtenidas o información relevante.



HERRAMIENTAS UTILES

- Metasploit Framework
- Routersploit
- Xarp
- SQLMap
- PowerSploit
- BurpSuite

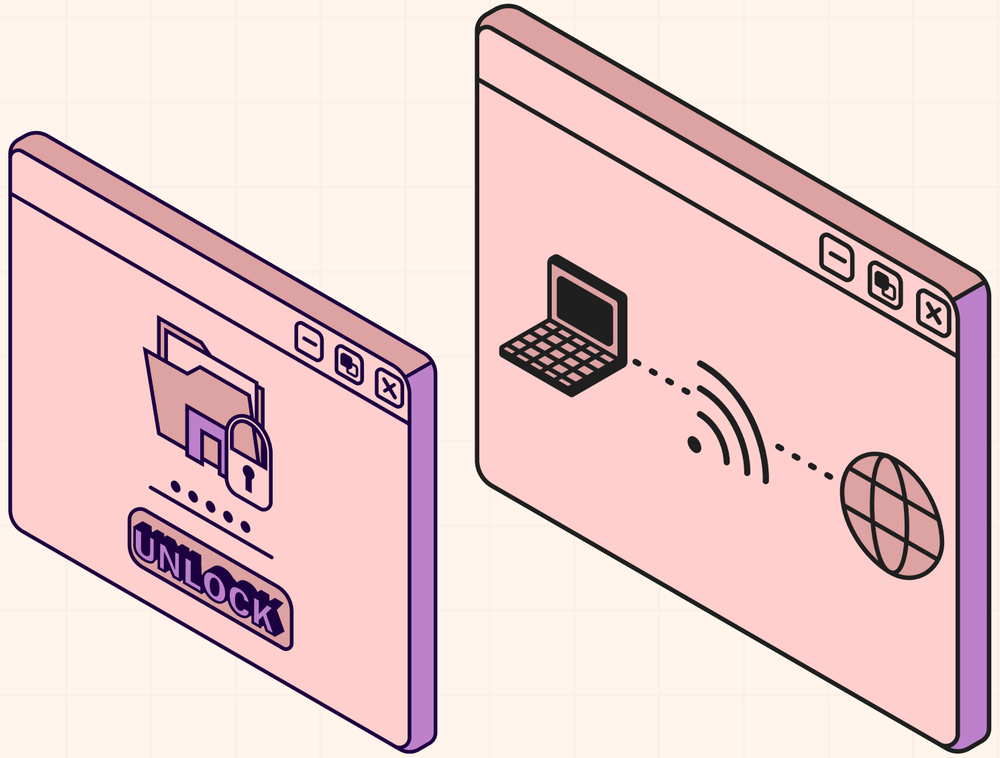




POST-EXPLOTACION

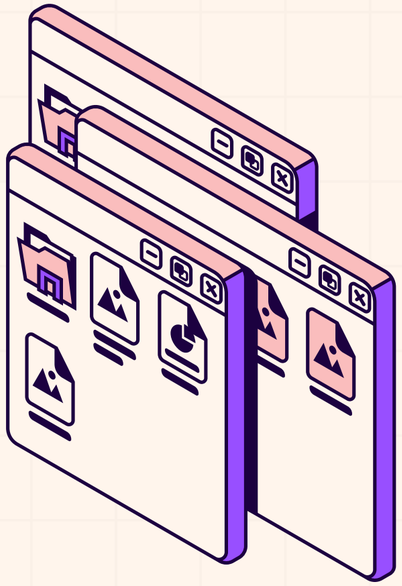
En la post explotación, se aprovecha el sistema comprometido para explorar a fondo el entorno, descubrir nuevos servicios e intentar establecer persistencia en el sistema para ganar acceso al sistema de nuevo. Algunos ejemplos son:

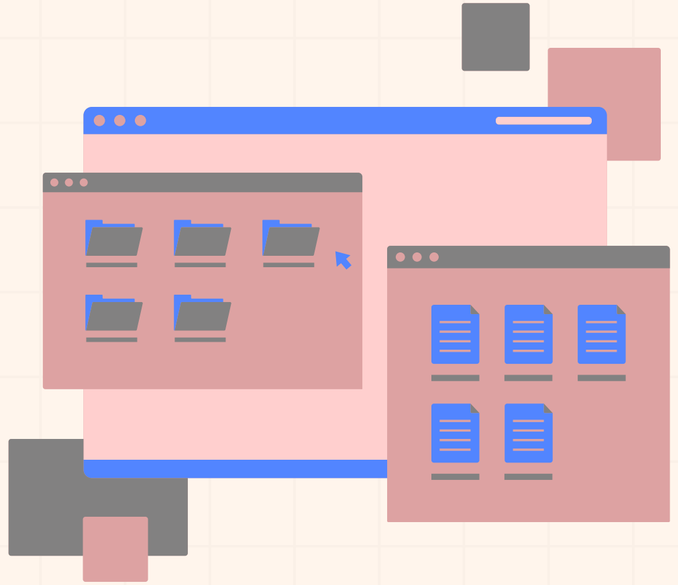
- Obtener información confidencial.
- Evadir mecanismos de autentificación
- Realizar acciones del lado de los usuarios
- Acceder a otros sistemas o servicios desde el sistema comprometido.
- Realizar acciones sin consentimiento
- y/o conocimiento de la empresa
- comprometida.



HERRAMIENTAS UTILES

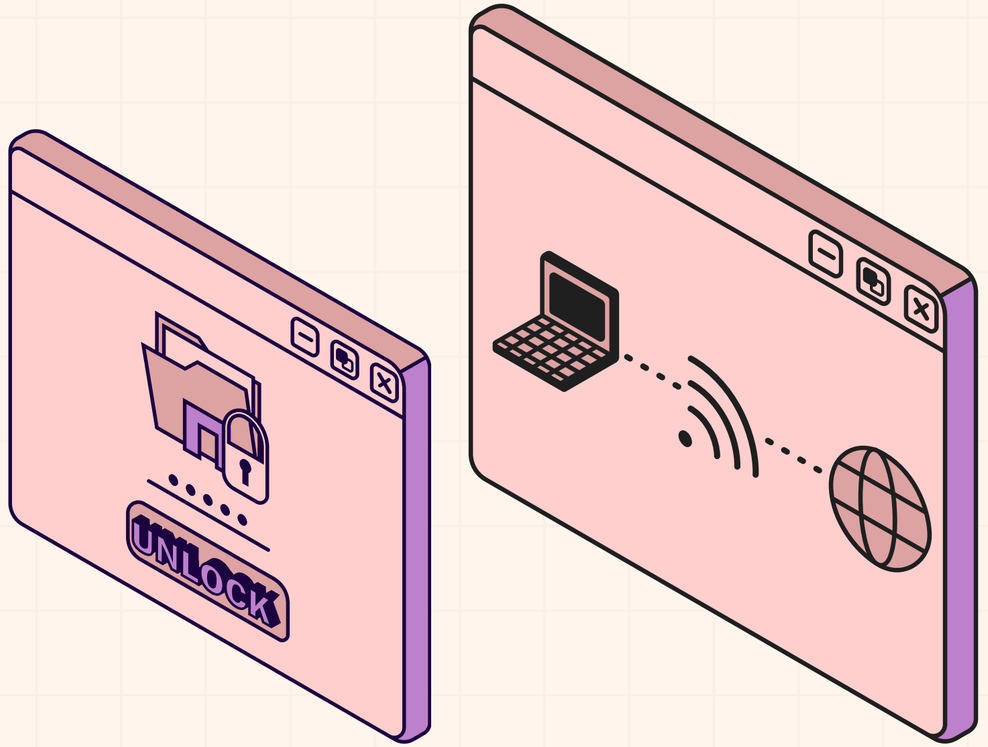
- Metasploit Framework
- TheFatRat
- ShellPop
- SQLMap
- PHPSploit
- Enumdb





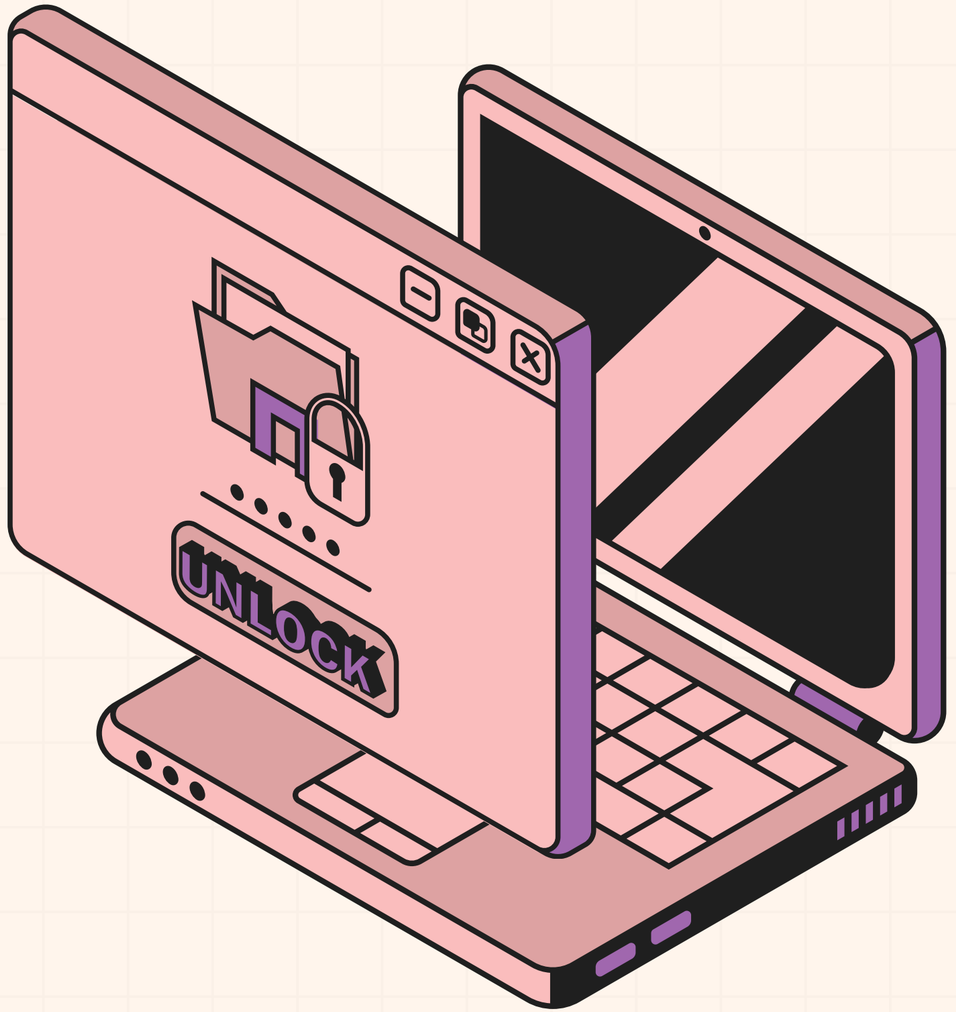
REPORTE

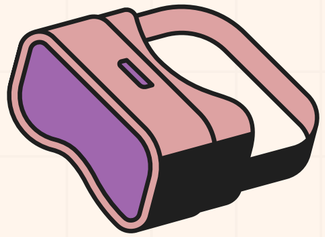
Se realiza un informe de vulnerabilidades. En esta fase se plasma todo lo que se ha realizado en el test de intrusión (las vulnerabilidades encontradas, los recursos desactualizados, etc.) También se plasma las contramedidas adecuadas para solucionar los fallos encontrados.

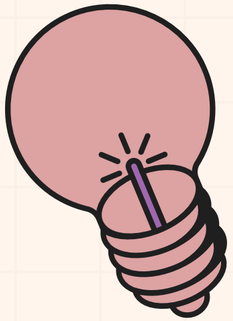


BIBLIOGRAFIA

- Fitzgerald, A. (2025, 14 julio). 20 Recent Cyber Attacks & What They Tell Us About the Future of Cybersecurity. Secureframe. [Link]
- Uberoi, A. (s. f.). January 2025: Recent cyber attacks, data breaches, ransomware attacks. [Link]
- Alcarria Lozano, P. (2023, 29 de septiembre). Fases del pentesting: Pasos para asegurar tus sistemas. OpenWebinars. [Link]
- EC-Council. (2022, 28 de marzo). The Five Phases of Penetration Testing. EC-Council Cybersecurity Exchange. [Link]







GRACIAS

